Отчёт по лабораторной работе № 3

Защита корпоративных ресурсов

Киберучения в формате Blue Team

Выполнили:

Рогозин Игорь

Гусейнов Тагир

Райко Матвей

Группа: НБИбд-01-23

Дата выполнения: 14 октября 2026 года

Содержание

1 Введение 3–3
1.1 Цель работы 3–3
1.2 Задачи 3–3
2 Сценарий и используемый стенд 4–5
3 Краткие теоретические сведения 5–6
3.1 ProxyLogon и ограничение доступа к ECP 5–5
3.2 Уязвимость обработки изображений в GitLab 6–6
3.3 Привилегированный доступ и COPY FROM PROGRAM 6–6
4 Обнаружение и восстановление последовательности атаки 7–13
4.1 Работа с событиями ViPNet IDS NS 7–7
4.2 События атаки на Exchange 8–9
4.3 События атаки на GitLab 9–10
4.4 События атаки на PostgreSQL 11–12
4.5 Хронология и сопоставление источников 12–13
5 Расследование и устранение на хостах 14–24
5.1 Microsoft Exchange 14–16
5.2 GitLab 16–20
5.3 PostgreSQL 20–24
6 Регистрация инцидентов 25–27
7 Результаты и обсуждение 28–29
7.1 Итоговые результаты по активам 28–29
7.2 Границы подтвержденного результата 29–29
8 Заключение 30–30
Приложение А Последовательность регистрации инцидентов 31–31
Приложение Б Реестр ключевых файлов расследования 32–32

1 Введение

В лабораторной работе мы исследовали учебную атаку на внутренние корпоративные ресурсы в полигоне Ampire. Нарушитель последовательно воздействовал на почтовый сервер Microsoft Exchange, сервер разработки GitLab и сервер PostgreSQL. Последствиями стали появление нелегитимного локального администратора, удаление содержимого репозитория и шифрование важных файлов.

Мы сопоставили события сетевого сенсора с состоянием хостов, сохранили материалы расследования, восстановили данные и изменили настройки доступа. Итоговый экран тренировки показывает устранение всех трех уязвимостей и трех последствий.

1.1 Цель работы

Установить последовательность и технические признаки атаки на корпоративные ресурсы, устранить выявленные причины и последствия в пределах учебного сценария, а затем проверить результат по состоянию сервисов, данных и интерфейсу тренировки.

1.2 Задачи

Изучить легенду и схему стенда, определить атакованные активы и источник подозрительной активности.

Найти события Exchange, GitLab и PostgreSQL в ViPNet IDS NS и сохранить сведения о правилах обнаружения.

Сопоставить сетевые события, отдельные пакеты и журналы приложений, отделив попытки действий от подтвержденных последствий.

Ограничить доступ к ECP, удалить нелегитимную учетную запись и завершить подтвержденные атакующие сеансы на Exchange.

Восстановить проект GitLab, обновить пакет и ограничить создание новых учетных записей.

Восстановить зашифрованные файлы PostgreSQL, изменить пароль и конфигурацию сетевого доступа.

Зафиксировать три инцидента и сопоставить итоговые статусы платформы с выполненными действиями.

2 Сценарий и используемый стенд

Работа выполнялась в тренировке «ЛР3 [НБИ-01-23 Alpha] v3», идентификатор 1041, группа «НБИбд-01-23 Alpha». Тренировка запущена 14 октября 2026 года в 15:27. По легенде сотрудник перед увольнением решил причинить ущерб организации и атаковал доступные ему внутренние ресурсы.

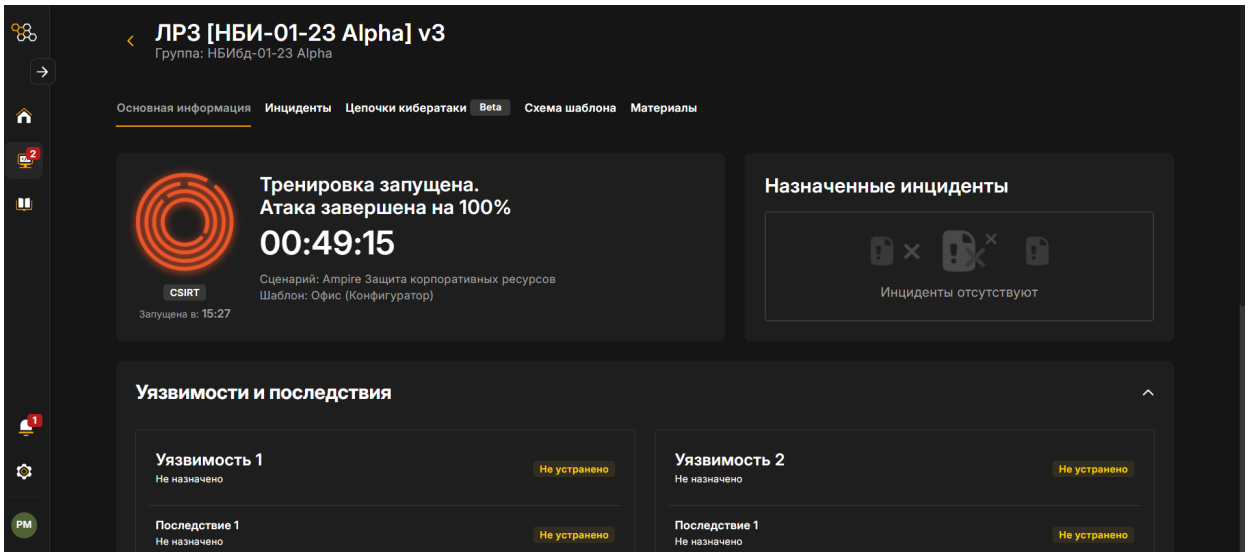


Рисунок 1 — Исходное состояние тренировки ЛР3 Alpha после завершения учебной атаки

Исходный экран показывает, что атака уже завершена. Поэтому в работе исследовались ее следы и последствия. Мы не запускали повторную эксплуатацию для воспроизведения ущерба.

Таблица 1 — Основные узлы учебного стенда

Узел	Адрес	Назначение
Insider	`10.10.4.55`	Источник атакующей активности по легенде и сетевым событиям
MS Exchange / MAIL	`10.10.2.11`	Почтовый сервер и приложение ECP в IIS
GitLab / ampire-gitlab	`10.10.2.18`	Сервер разработки и репозиторий `Very sensitive project`
PostgreSQL / postgrdeb	`10.10.2.26`	Сервер БД и каталог важных файлов
ViPNet IDS NS	`10.10.2.21`	Сетевой сенсор обнаружения атак
Internal Router	`10.10.2.254`	Маршрутизатор, адрес которого присутствует в части наблюдений
Active Directory	`10.10.2.10`	Инфраструктурные службы стенда

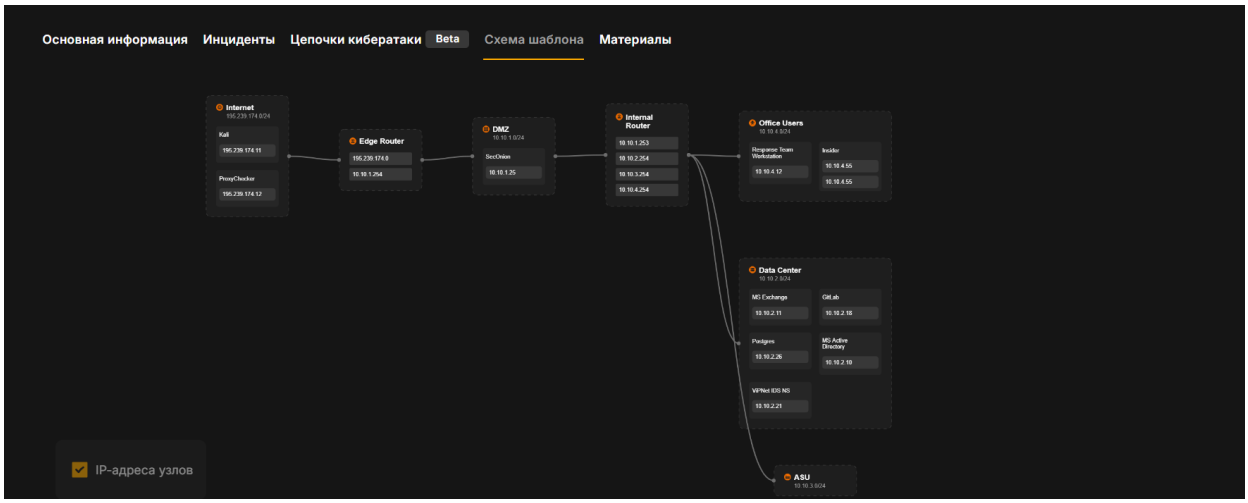


Рисунок 2 — Схема узлов и сетевых связей учебного шаблона

Сеть стенда отделена от адресов подключения к учебной инфраструктуре. В частности, `10.140.2.133` использовался как удаленная рабочая станция, а веб-интерфейс Ampire был доступен по адресу `10.140.2.13`. В таблице приведены внутренние адреса, по которым сопоставлялись события и состояние активов.

Времена в интерфейсе IDS и журналах сопоставлялись с московским временем. Имена выгруженных PCAP содержат отметку UTC: например, 12:29:14Z соответствует 15:29:14 по Москве. Это различие учитывалось при восстановлении хронологии.

3 Краткие теоретические сведения

3.1 ProxyLogon и ограничение доступа к ECP

В сценарии Exchange используется цепочка ProxyLogon: SSRF `CVE-2021-26855` сочетается с `CVE-2021-27065`, связанной с записью файла. ECP является административным веб-приложением Exchange и участвует в этой цепочке. Методические указания предлагают ограничить доступ к `/ecp`, затем устранить активные соединения и созданного пользователя.

Ограничение административного URL уменьшает доступную поверхность атаки. Его следует отличать от установки исправлений и проверки уже скомпрометированной системы: Microsoft рассматривает временные меры как дополнение к обновлению, а не как подтверждение полной очистки сервера.

3.2 Уязвимость обработки изображений в GitLab

CVE-2021-22205 относится к удаленному выполнению команд при обработке загружаемых изображений в GitLab. В рассматриваемой цепочке задействован сторонний обработчик ExifTool; связанная с ним уязвимость обозначается CVE-2021-22204. Поэтому в событиях сенсора встречаются оба идентификатора, относящиеся к разным уровням цепочки.

GitLab указывает версию 13.10.3 среди выпусков, содержащих исправление CVE-2021-22205. Именно она использовалась как целевая версия в данной лабораторной работе. Перед обновлением требовалось восстановить удаленные данные из резервной копии, подходящей к исходной версии и редакции.

3.3 Привилегированный доступ и COPY FROM PROGRAM

Команда COPY FROM PROGRAM запускает указанную программу на стороне сервера PostgreSQL. В PostgreSQL 13 такой доступ ограничен суперпользователями и соответствующими привилегированными ролями. Следовательно, существенным условием рассматриваемой атаки был доступ к привилегированной роли в сочетании с чрезмерно широким сетевым доступом.

В сенсоре и методичке этот этап связан с CVE-2019-9193 и обозначен как Postgres misconfig. Практические меры направлены на устранение небезопасной конфигурации: ограничение прослушиваемых адресов и правил pg_hba.conf, смену пароля и прекращение нежелательных сеансов. Само наличие функции COPY не означает возможность ее вызова любым непривилегированным клиентом.

4 Обнаружение и восстановление последовательности атаки

4.1 Работа с событиями ViPNet IDS NS

В разделе «События» ViPNet IDS NS были найдены срабатывания по трем атакованным активам. Для разделения этапов использовался фильтр «Получатель → IP-адрес». В списке сопоставлялись время, имя правила, адреса и порты; в карточке события проверялись код и класс правила.

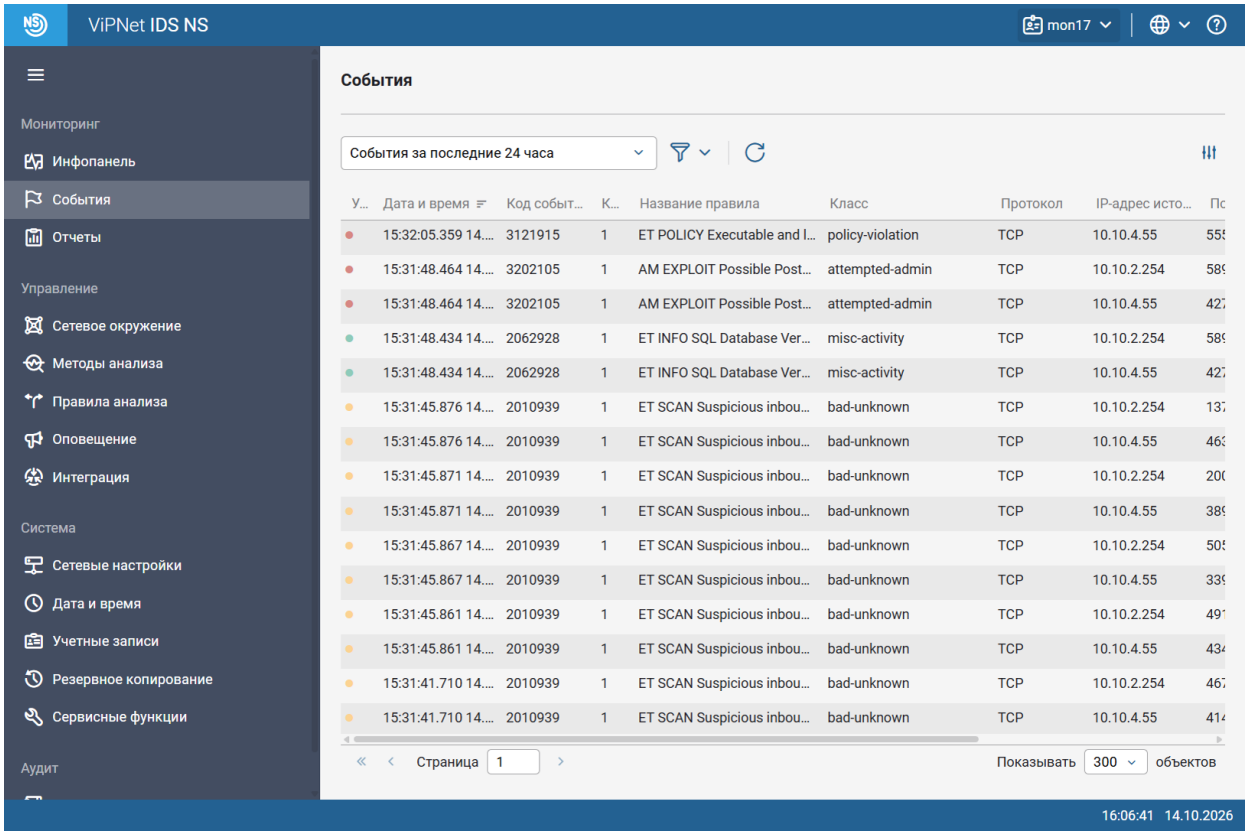


Рисунок 3 — Общий список сетевых событий ViPNet IDS NS

Для каждого актива сохранены общий список релевантных событий и подробности одного характерного срабатывания. Такая пара позволяет связать контекст сетевой активности с конкретной сигнатурой, не подменяя расследование одним названием правила.

4.2 События атаки на Exchange

При фильтрации по получателю `10.10.2.11` обнаружены события загрузки исполняемого файла и характерной активности Metasploit. Время 15:28:34 предшествует этапам GitLab и PostgreSQL. В наблюдаемом обмене фигурируют источник `10.10.4.55:5556` и порты 7449/7450 на Exchange.

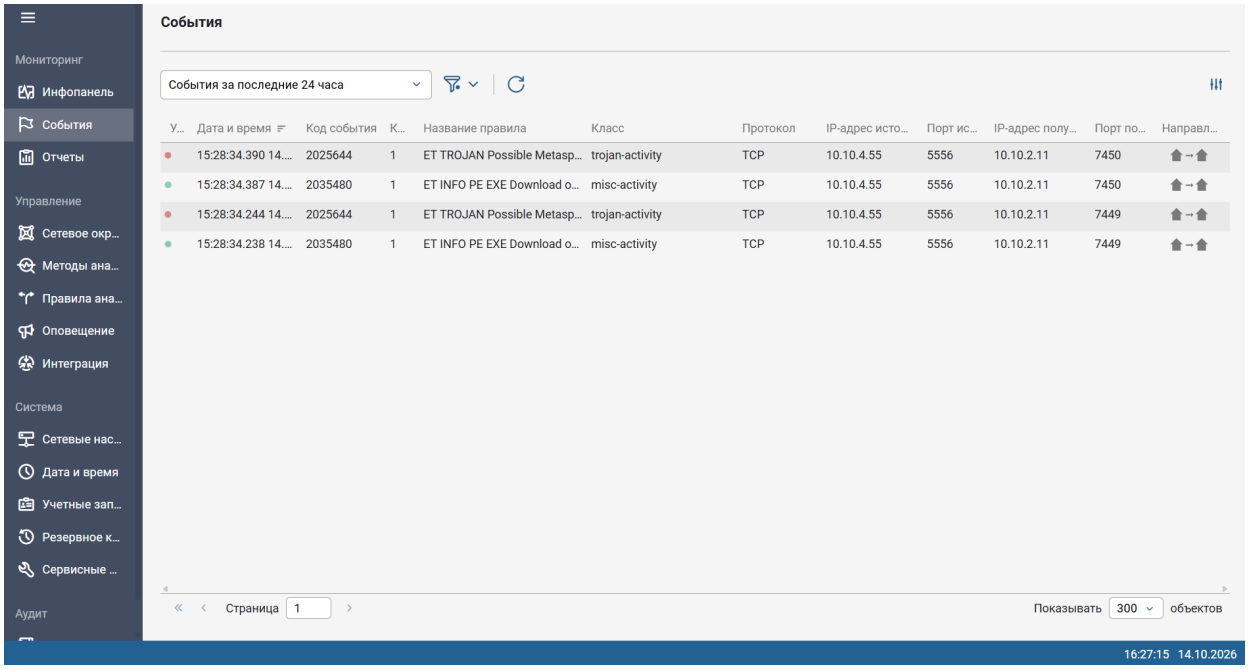


Рисунок 4 — События сенсора по получателю MS Exchange 10.10.2.11

В подробностях события 15:28:34.390 указано правило «ET TROJAN Possible Metasploit Payload Common Construct Bind_API (from server)», код 2025644, класс trojan-activity. Это сетевой признак вредоносной нагрузки; сведения о созданной учетной записи проверялись отдельно на самом сервере.

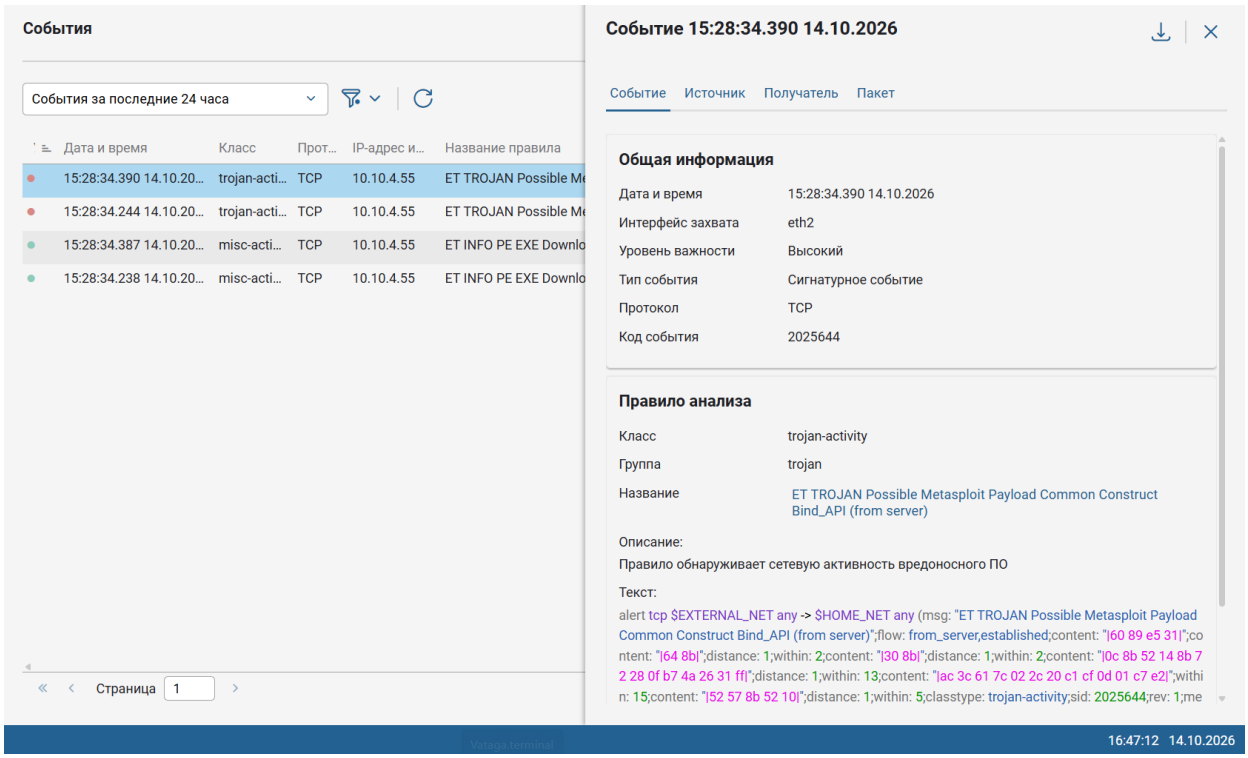


Рисунок 5 — Подробности правила 2025644 для активности Metasploit на Exchange

4.3 События атаки на GitLab

Для `10.10.2.18` в 15:29:14 найдены срабатывания на обработку изображения ExifTool, внедрение команд и загрузку ELF-файла. Сочетание событий указывает на этап выполнения команд с последующим получением исполняемой нагрузки.

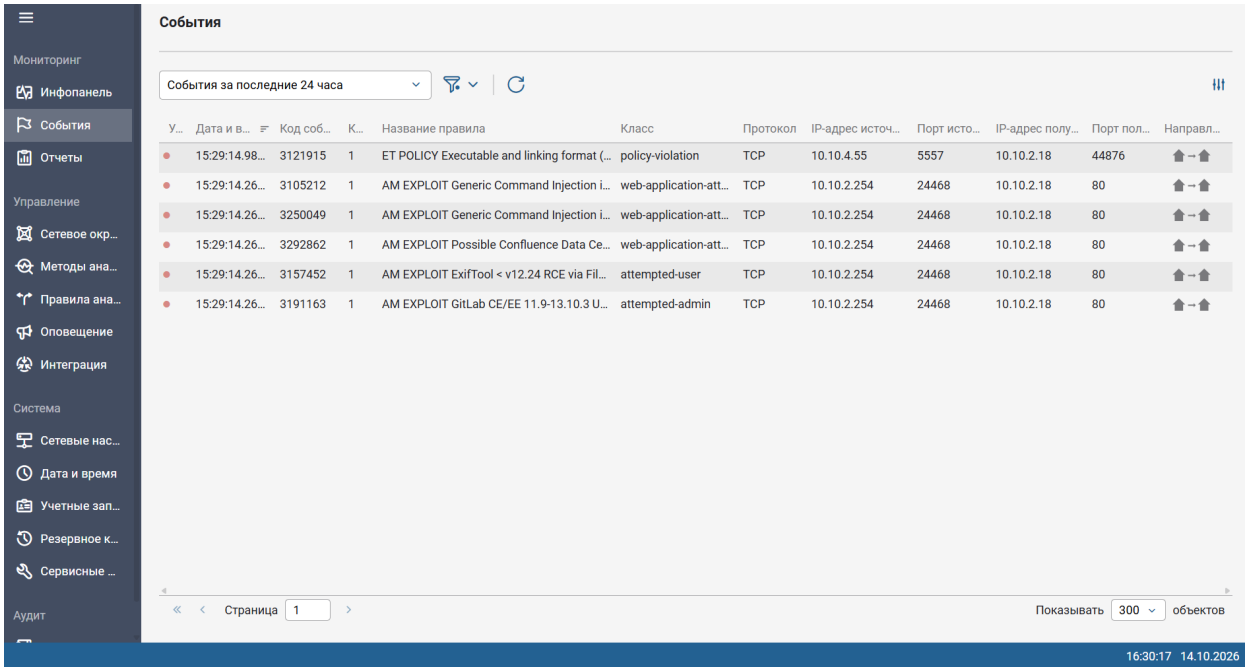


Рисунок 6 — События внедрения команд и загрузки ELF для GitLab 10.10.2.18

Характерное событие 15:29:14.264 имеет код 3191163 и имя «AM EXPLOIT GitLab CE/EE … Unauthenticated Remote ExifTool Command Injection (CVE-2021-22205)». В сетевом наблюдении источником HTTP-запроса является 10.10.2.254. Это фактически наблюдаемый адрес; механизм преобразования адресов дополнительно не проверялся.

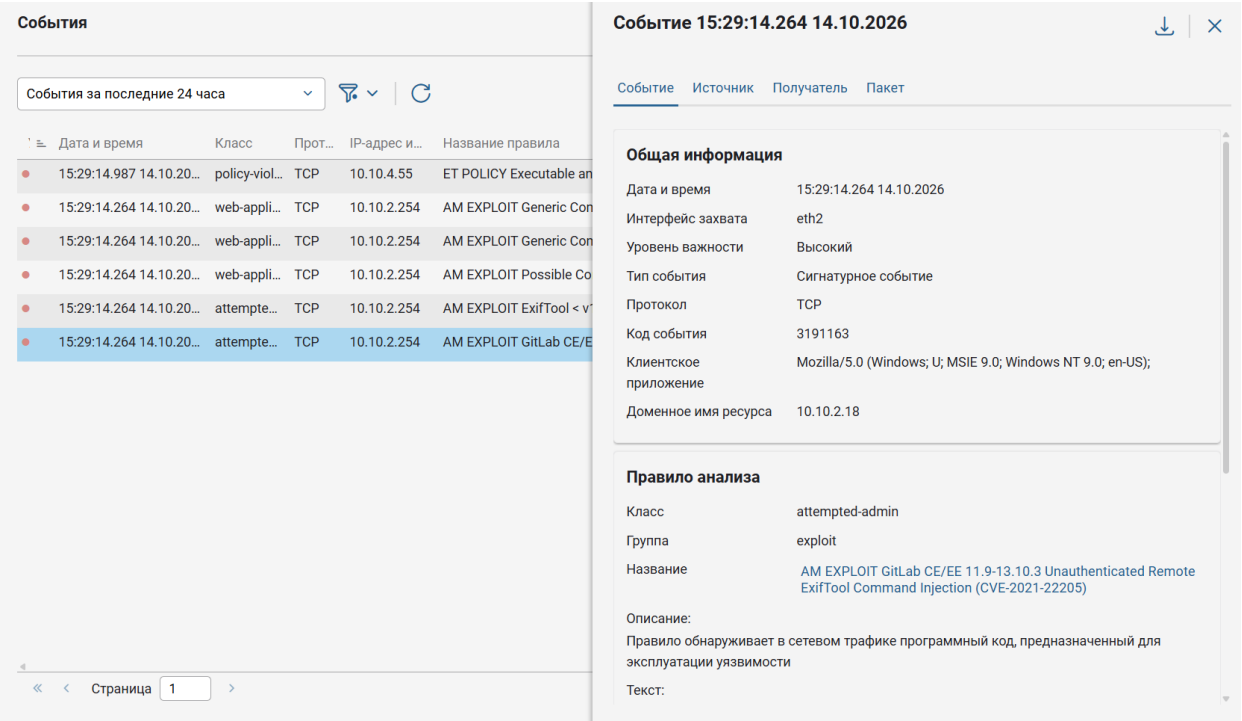


Рисунок 7 — Карточка правила 3191163 об эксплуатации GitLab через ExifTool

4.4 События атаки на PostgreSQL

При фильтрации по `10.10.2.26` видны обнаружение версии СУБД, сканирование порта 5432, признаки `COPY FROM PROGRAM` и загрузка ELF. Событие 15:31:48.464 имеет код 3202105; правило относит активность к попытке получения административного доступа.

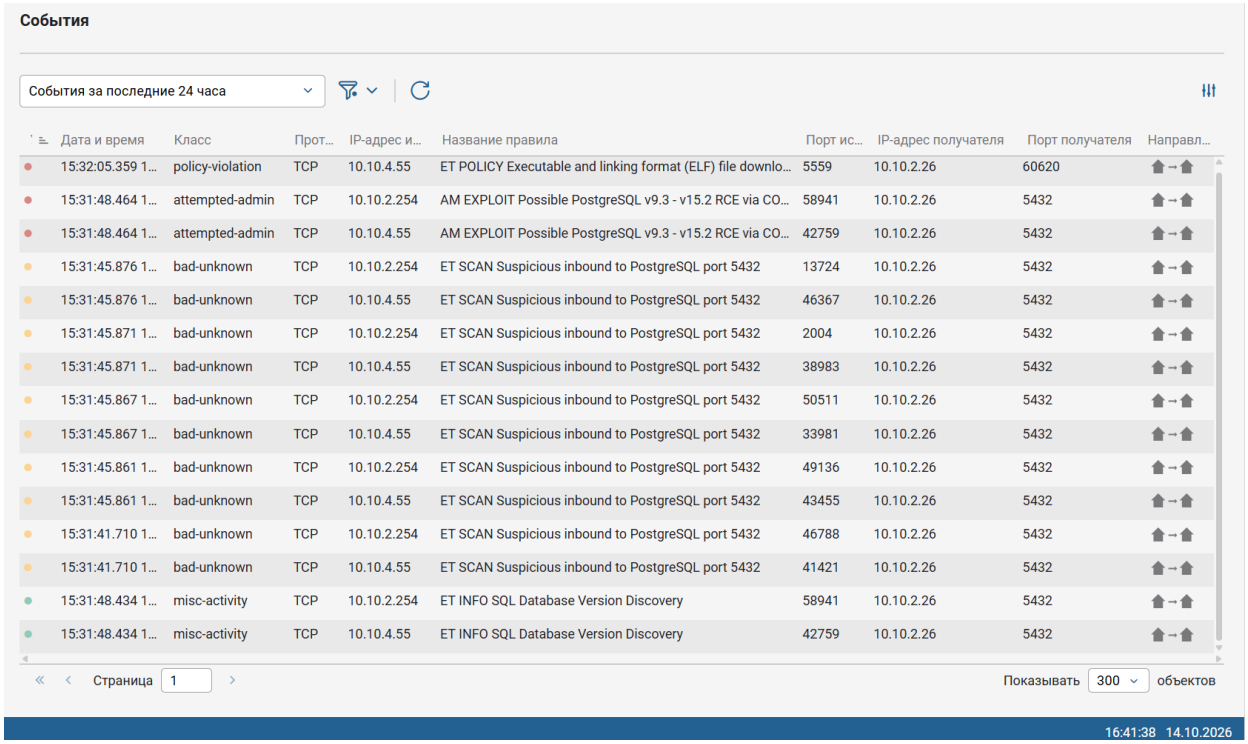


Рисунок 8 — Последовательность сетевых событий для PostgreSQL 10.10.2.26

Полное имя выбранной сигнатуры содержит «AM EXPLOIT Possible PostgreSQL v9.3 - v15.2 RCE via `COPY FROM PROGRAM` (`CVE-2019-9193`, `CVE-2022-31659`)». Идентификаторы из имени правила использовались как ориентир расследования. Реальные выполненные команды и их результат проверялись по журналу PostgreSQL и файлам на хосте.

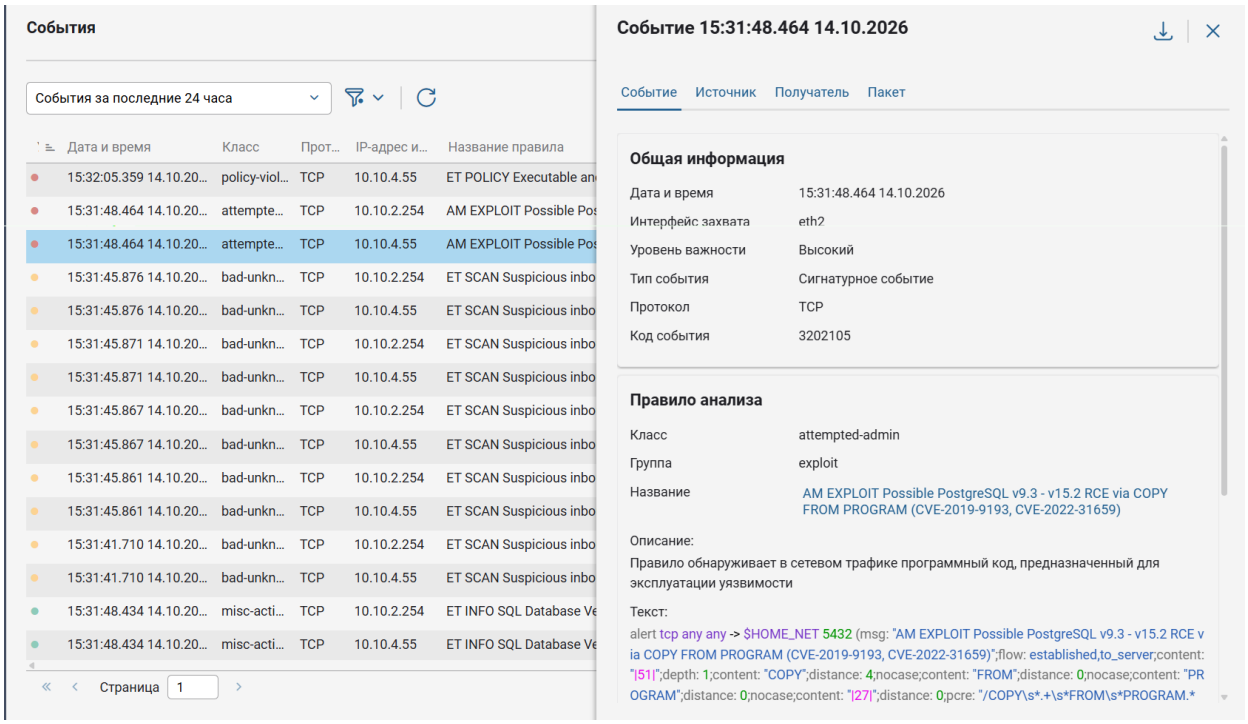


Рисунок 9 — Карточка правила 3202105 о COPY FROM PROGRAM

4.5 Хронология и сопоставление источников

Таблица 2 — Ключевые моменты атаки 14 октября 2026 года

Время МСК	Актив	Наблюдение	Подтверждение
15:28:34	Exchange	Обмен с `10.10.4.55:5556`, признаки Metasploit	IDS; позднее обнаружены соответствующие PowerShell-соединения
15:29:14.264	GitLab	Загрузка изображения с командной нагрузкой	Правило 3191163 и отдельный HTTP-пакет
15:29:14	GitLab	Процесс `/tmp/idMnwN` от пользователя git	Состояние процесса и TCP-соединение на 5557
15:31:48.464	PostgreSQL	Команда `COPY FROM PROGRAM`	Правило 3202105, отдельный SQL-пакет и журнал
15:32:05.359	PostgreSQL	Передача части ELF-файла	Правило 3121915 и отдельный пакет
15:32:19	PostgreSQL	Запуск закодированного скрипта через `hacker_table`	Записи журнала и зашифрованный архив

Из IDS выгружены три PCAP с отдельными пакетами: SQL-командой к PostgreSQL, фрагментом ELF и запросом загрузки изображения в GitLab. Это фрагменты обмена, а не полный сетевой сеанс. По ним подтверждаются адреса, порты и содержимое отдельных сообщений; они не доказывают успех всех последующих действий.

В HTTP-пакете GitLab использован POST `/gitlab/uploads/user`. Файл `4RnGPh.jpg` содержал данные DjVu и командную нагрузку, связанную с запуском `/tmp/idMnwN`. В SQL-пакете зафиксирован вызов `COPY FROM PROGRAM` с попыткой обратного подключения на `10.10.4.55:5558`. Сопоставление с журналом показало для этой попытки ошибку Bash «`Bad file descriptor`», поэтому успешная интерактивная оболочка по этому эпизоду не утверждается.

5 Расследование и устранение на хостах

5.1 Microsoft Exchange

На сервере MAIL обнаружен локальный пользователь `hacker`. Во вкладке `Member Of` его свойств указана группа `Administrators`. Таким образом, последствие Exchange User подтверждается состоянием учетной записи на самом хосте, а не только легендой тренировки.

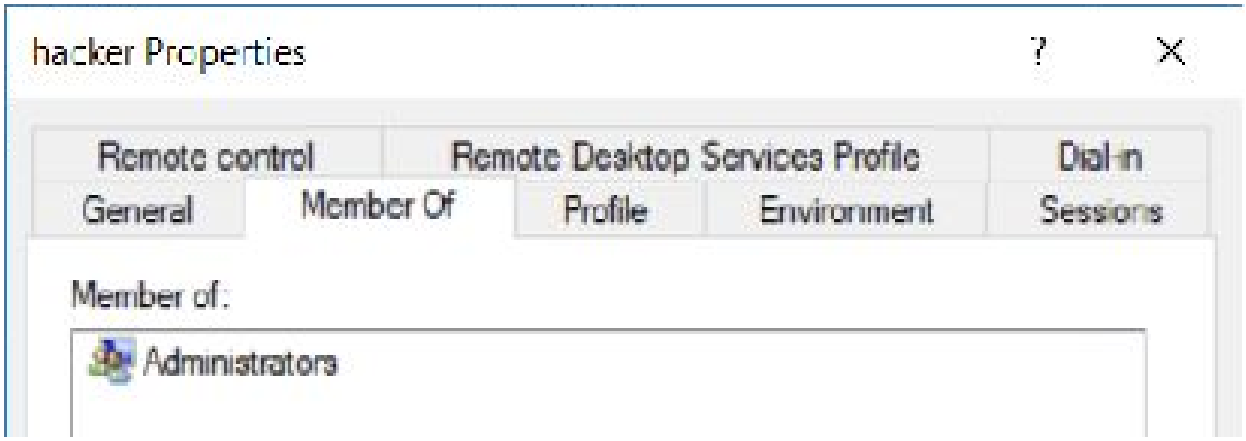


Рисунок 10 — Пользователь hacker состоит в локальной группе Administrators

В Resource Monitor обнаружены два процесса `powershell.exe` с PID 14552 и 14576. Их соединения `10.10.2.11:7449/7450 → 10.10.4.55:5556` совпадают с парой портов из событий IDS. Это позволило выбрать конкретные процессы для завершения, не затрагивая остальные сеансы PowerShell и штатные службы Exchange.

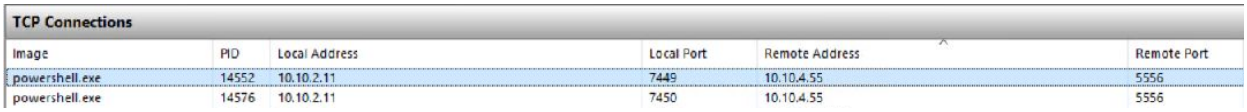


Рисунок 11 — Два подтвержденных соединения PowerShell с источником атаки до устранения

В IIS Manager открыт путь MAIL → Sites → `Default Web Site` → ecp → `IP Address and Domain Restrictions`. В `Edit Feature Settings` значение `Access for unspecified clients` изменено на `Deny` и сохранено. Настройка повторно открыта для проверки. Тип ответа `Deny Action Type` оставлен `Not Found`, как в примере методички; отдельных разрешающих IP-правил в списке не было.

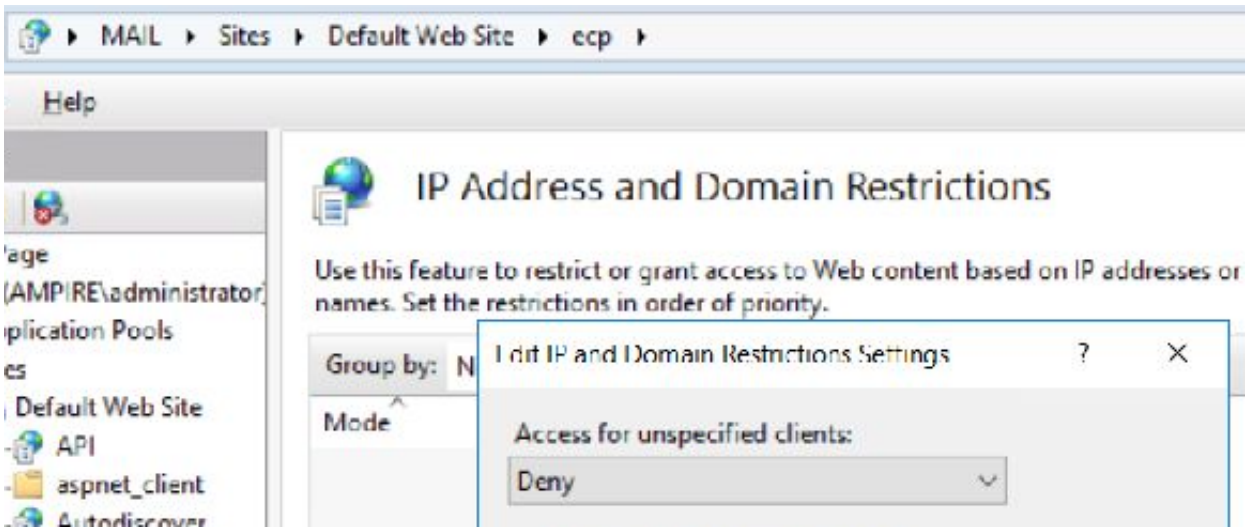


Рисунок 12 — Повторная проверка сохраненного Deny для неопределенных клиентов приложения ecp

Для подтвержденного атакующего процесса выполнено `End Process`. После возобновления мониторинга PID 14552 и 14576 отсутствовали в обновленном списке процессов. В TCP-таблице, отсортированной по `Remote Address`, соединений с `10.10.4.55` больше не наблюдалось.

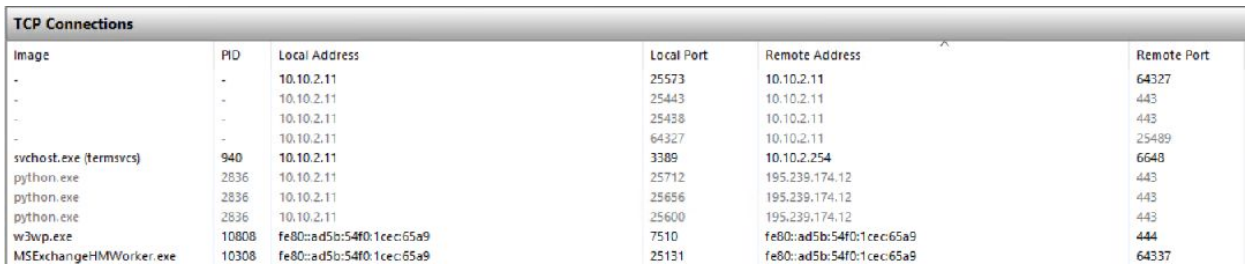


Рисунок 13 — После устранения в отсортированной TCP-таблице отсутствует адрес 10.10.4.55

Пользователь `hacker` удален через оснастку `Local Users and Groups`. После подтверждения удаления список обновлен клавишей F5. В нем остаются `Administrator`, `DefaultAccount`, frunklin, Guest и John; `hacker` отсутствует.

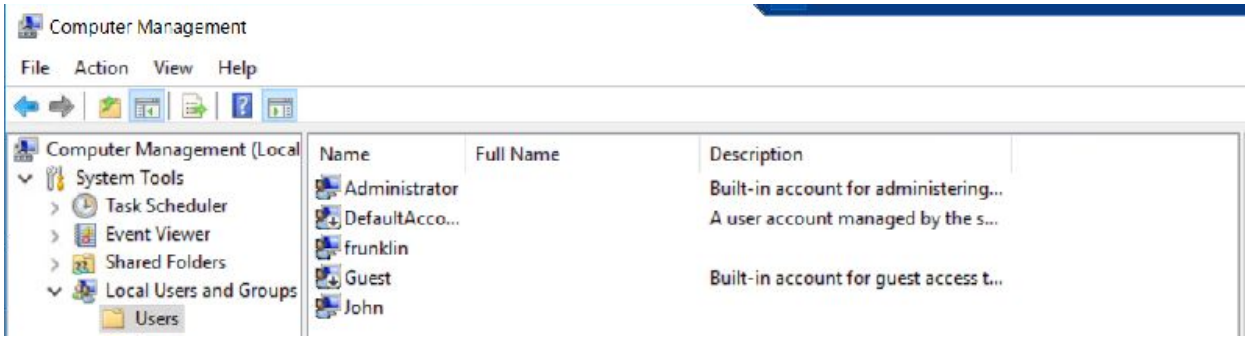


Рисунок 14 — Обновленный список локальных пользователей MAIL после удаления hacker

Для Exchange подтверждены ограничение ECP, удаление нелегитимного администратора и отсутствие прежних атакующих соединений на момент проверки. Отдельный внешний HTTP-тест запрета ECP и проверка установленного пакета исправлений не выполнялись.

5.2 GitLab

Работа с GitLab выполнялась на хосте ampire-gitlab, `10.10.2.18`. Исходно использовалась редакция Enterprise Edition версии `13.10.2-ee.0`. В процессах найден `/tmp/idMnwN` с PID 2697, запущенный от пользователя git в 15:29:14, что согласуется со временем загрузки из сетевого события.

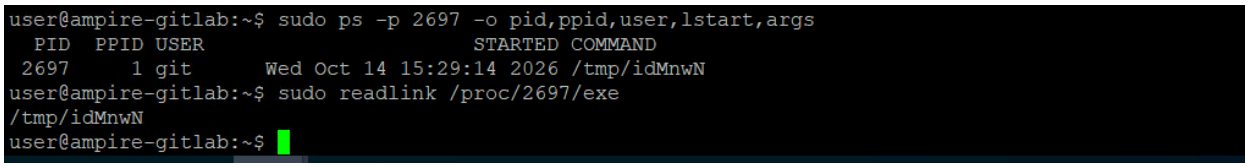


Рисунок 15 — Обнаруженный процесс /tmp/idMnwN с PID 2697 и временем запуска 15:29:14

Перед завершением процесса он был приостановлен, а исполняемый файл сохранен через `/proc/2697/exe` в каталоге `/home/user/lr3-gitlab-evidence`. Вместе с ним сохранены журналы nginx и `gitlab-rails`, конфигурация `gitlab.rb`, файл `gitlab-secrets.json` и стабильная резервная копия. Доступ к собранным материалам ограничен. Для сохраненного бинарного файла вычислена SHA-256; ее значение приведено в приложении Б.



Рисунок 16 — Контрольная сумма сохраненного файла и проверка соединений после завершения процесса

После сохранения доказательств процесс завершен. Проверка ss по адресу `10.10.4.55` вернула пустой вывод. Соединение с данным адресом на момент проверки отсутствовало.

В веб-интерфейсе проект `Very sensitive project` существовал, однако его репозиторий был пуст. Это соответствует последствию GitLab deleter. Для восстановления использована `stable_gitlab_backup.tar`, подготовленная для исходной версии `13.10.2-ee`.

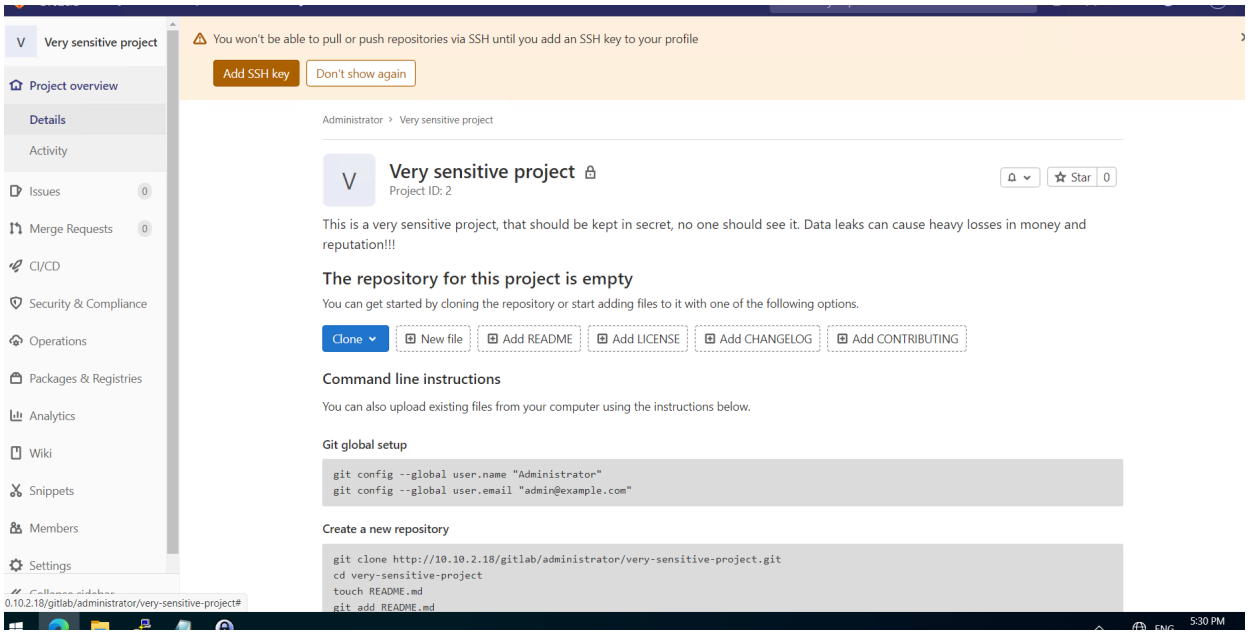


Рисунок 17 — Пустой репозиторий Very sensitive project до восстановления

Перед восстановлением остановлены Puma и Sidekiq. Затем запущено восстановление стабильной копии. Такой порядок сохраняет соответствие версии приложения и формата резервной копии: сначала восстанавливаются данные исходной установки, затем выполняется обновление пакета.

```
sudo gitlab-ctl stop puma
sudo gitlab-ctl stop sidekiq
sudo gitlab-backup restore BACKUP=stable
sudo gitlab-ctl reconfigure
sudo gitlab-ctl restart
```

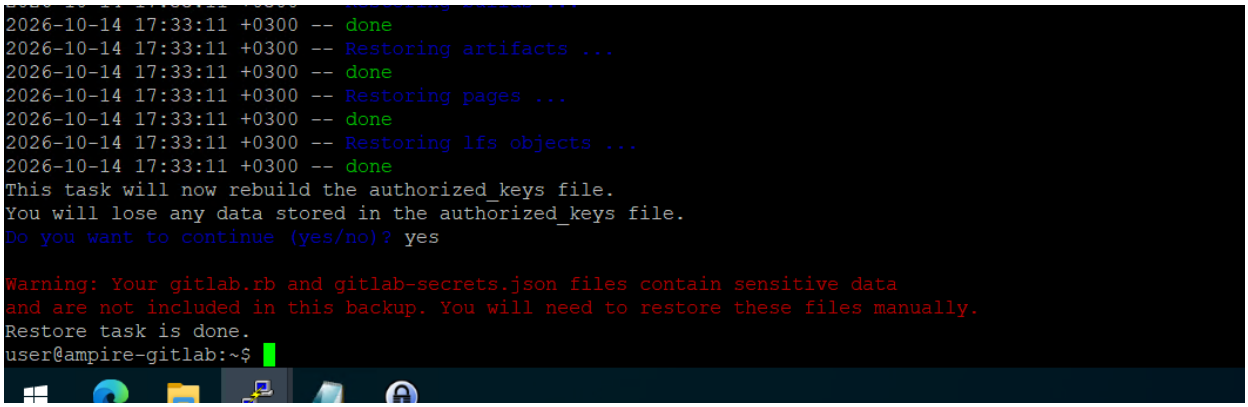


Рисунок 18 — Завершение восстановления стабильной резервной копии GitLab

После восстановления и перезапуска службы находились в состоянии `run`, а в проекте появились `README.md` и `main.py`. В ветке `master` видны восстановленные коммиты. Дополнительно перед обновлением была создана свежая резервная копия `1791989995_2026_10_14_13.10.2-ee_gitlab_backup.tar`; первая операция завершилась сообщением `Backup task is done`.

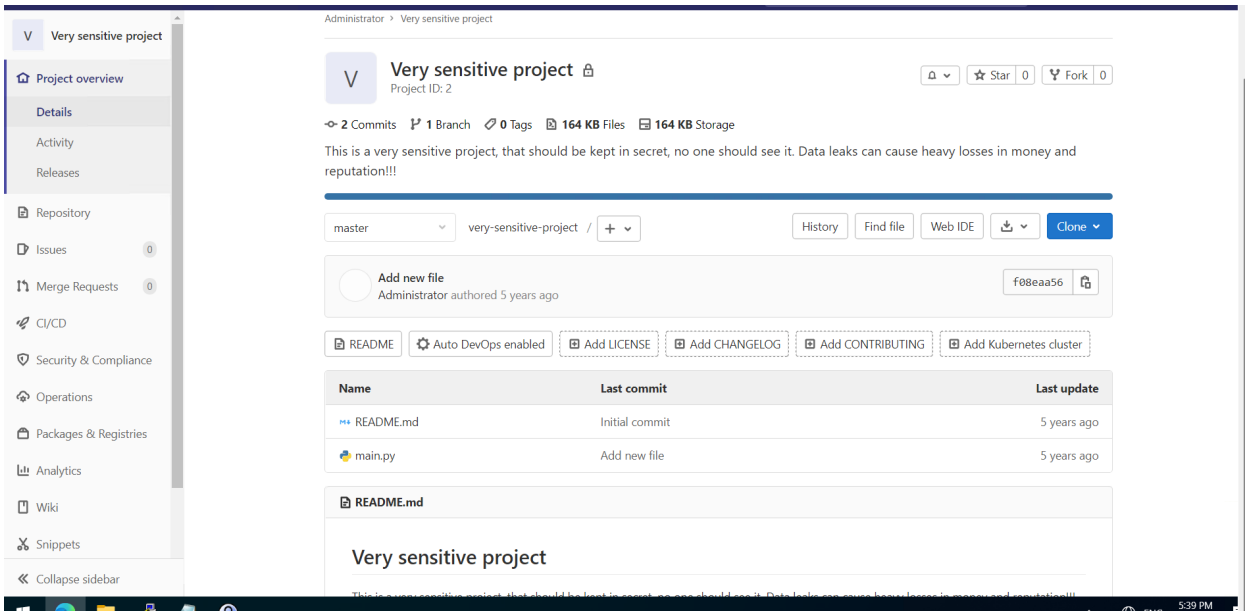


Рисунок 19 — Восстановленные README.md и main.py в проекте GitLab

Обновление выполнено локальным пакетом `gitlab-ce_13.10.3-ce.0_amd64.deb` из учебного каталога обновлений. Перед установкой проверены имя пакета, версия и архитектура: `gitlab-ce`, `13.10.3-ce.0`, amd64. Использование локального пакета позволило выполнить этап при недоступных внешних репозиториях.

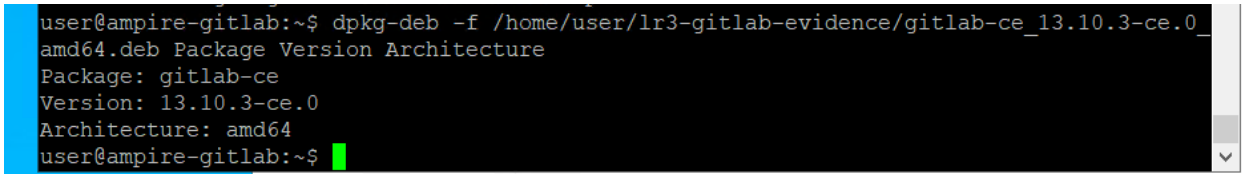


Рисунок 20 — Метаданные локального пакета GitLab CE 13.10.3 для amd64

Поскольку пакет менял редакцию EE на CE, предварительно проверены используемые возможности: Kerberos выключен, интеграций `GithubService` нет, переменных CI с ограничением окружения в проверенной категории нет.

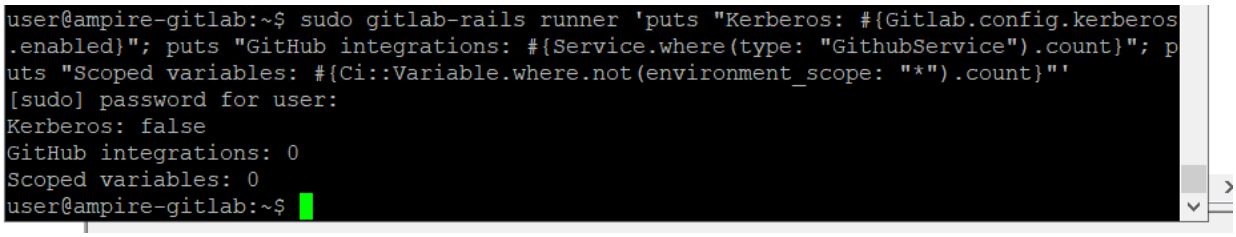


Рисунок 21 — Проверка перечисленных зависимостей перед переходом с EE на CE

```
sudo dpkg -i \
  /home/user/lr3-gitlab-evidence/gitlab-ce_13.10.3-ce.0_amd64.deb
```

Установка завершилась сообщением `Upgrade complete`. Последующий `dpkg-query` подтвердил `gitlab-ce 13.10.3-ce.0`, а `gitlab-ctl status` показал все 15 служб в состоянии `run`. После обновления повторно проверена доступность восстановленного проекта через веб-интерфейс.

```
user@ampire-gitlab:~$ dpkg-query -W gitlab-ce
gitlab-ce       13.10.3-ce.0
user@ampire-gitlab:~$ sudo gitlab-ctl status
run: alertmanager: (pid 20541) 82s; run: log: (pid 1607) 17016s
run: gitaly: (pid 20561) 82s; run: log: (pid 1604) 17016s
run: gitlab-exporter: (pid 20544) 82s; run: log: (pid 1603) 17016s
run: gitlab-workhorse: (pid 20527) 83s; run: log: (pid 1601) 17016s
run: grafana: (pid 20571) 82s; run: log: (pid 1597) 17016s
run: logrotate: (pid 20580) 81s; run: log: (pid 1609) 17016s
run: nginx: (pid 20586) 81s; run: log: (pid 1605) 17016s
run: node-exporter: (pid 20592) 80s; run: log: (pid 1610) 17016s
run: postgres-exporter: (pid 20597) 80s; run: log: (pid 1612) 17016s
run: postgresql: (pid 23170) 8958s; run: log: (pid 1599) 17016s
run: prometheus: (pid 20681) 79s; run: log: (pid 1608) 17016s
run: puma: (pid 20690) 79s; run: log: (pid 1613) 17016s
run: redis: (pid 23193) 8957s; run: log: (pid 1611) 17016s
run: redis-exporter: (pid 20696) 79s; run: log: (pid 1598) 17016s
run: sidekiq: (pid 20702) 78s; run: log: (pid 1606) 17016s
user@ampire-gitlab:~$
```

Рисунок 22 — Итоговая версия GitLab CE 13.10.3-ce.0 и состояние 15 служб

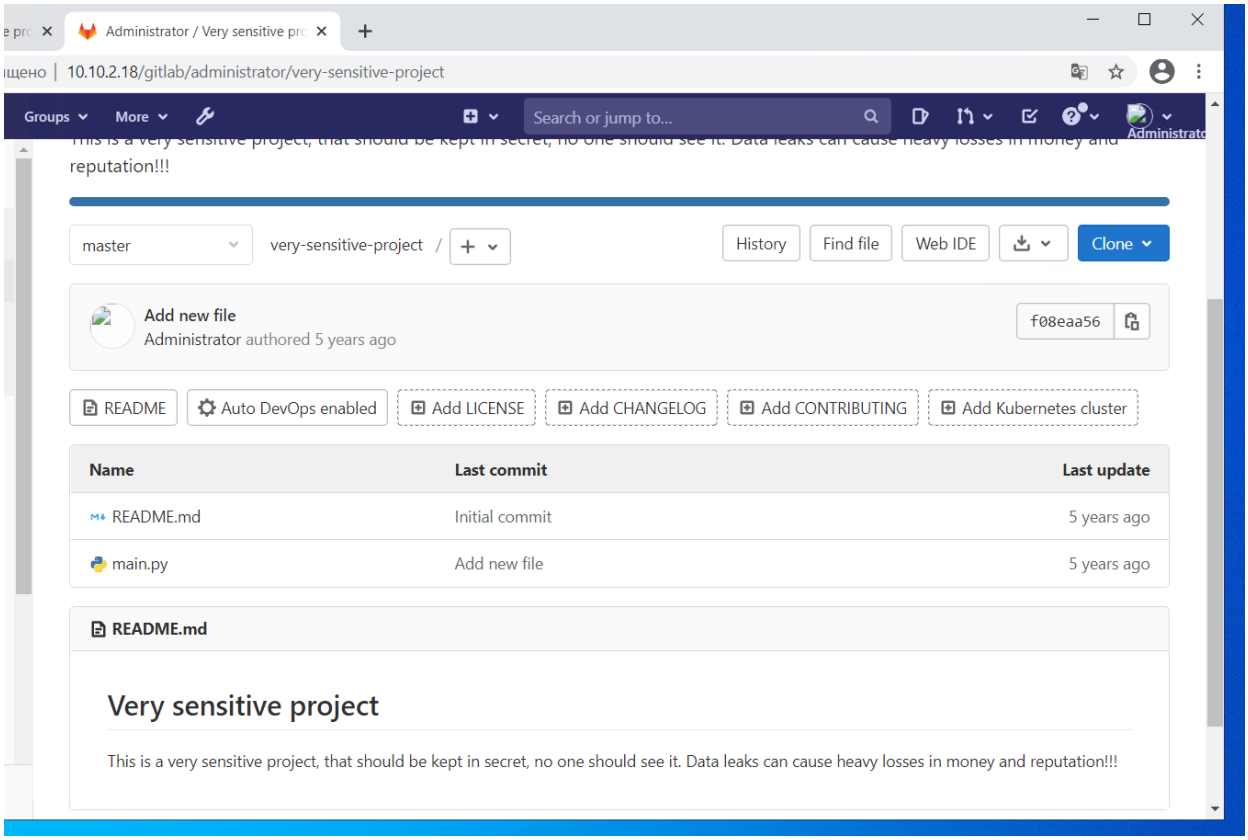


Рисунок 23 — Восстановленный проект доступен после обновления GitLab

Полный список пользователей после восстановления и обновления содержит `administrator` и внутреннего пользователя `ghost`. Аккаунт нарушителя `Script Kiddie` в списке отсутствует. Служебный `ghost` не удалялся.

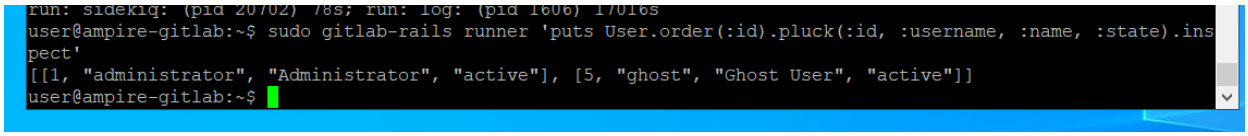


Рисунок 24 — Полный список пользователей после восстановления и обновления

В `Sign-up restrictions` включено `Require admin approval for new sign-ups`. При этом `Sign-up enabled` осталось включенным: регистрация требует одобрения администратора, а не полностью отключена. Изменение сохранено, интерфейс выдал сообщение `Application settings saved successfully`.

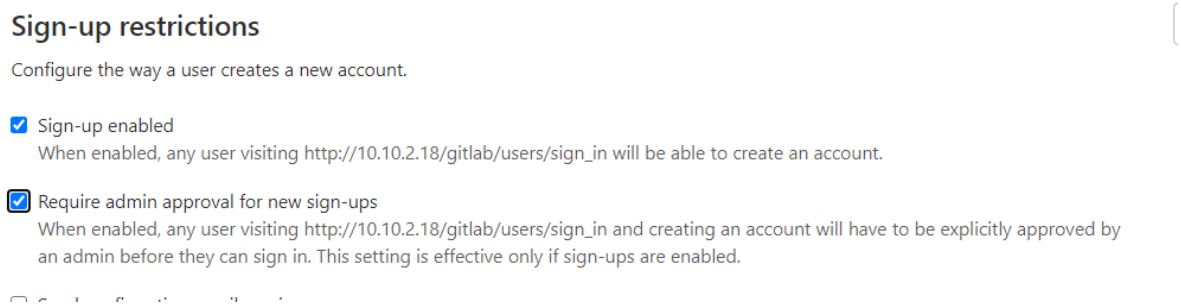


Рисунок 25 — Для новых регистраций включено подтверждение администратором

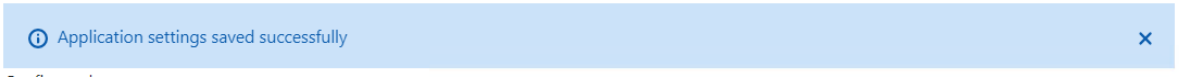


Рисунок 26 — Интерфейс подтверждает успешное сохранение настроек GitLab

Завершающая проверка соединений с источником атаки не вывела строк и вернула приглашение командной оболочки. В совокупности с восстановленным проектом и проверкой версии это подтверждает выполнение предусмотренных шагов по GitLab.

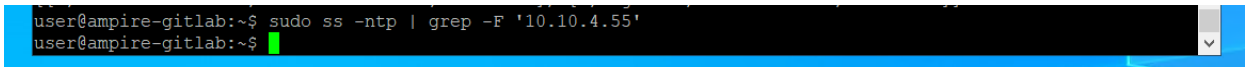


Рисунок 27 — Итоговая проверка GitLab не показывает соединений с 10.10.4.55

5.3 PostgreSQL

На хосте postgrdeb, `10.10.2.26`, обнаружен архив `important_files.tar.gz.aes` размером около 43 МБ. По журналу PostgreSQL сопоставлены операции с таблицей `hacker_table` и запуск программы через `COPY FROM PROGRAM`. В одном из эпизодов команда содержала закодированный Base64-скрипт. Его содержимое декодировано как текст без выполнения.

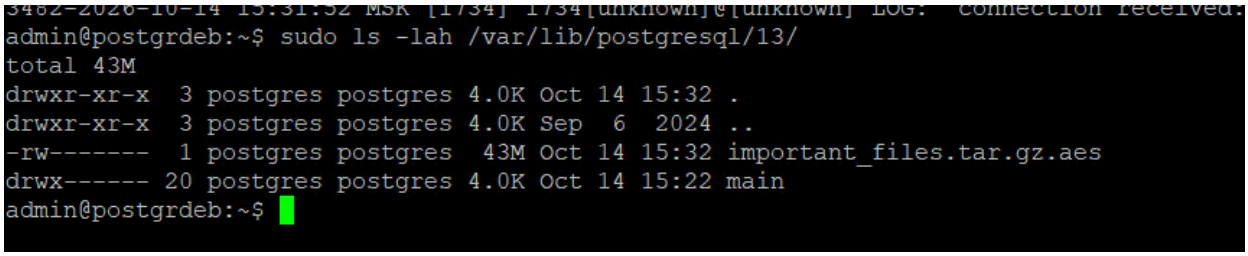


Рисунок 28 — Зашифрованный архив важных файлов в каталоге PostgreSQL

Исходный журнал и зашифрованный архив скопированы в `/home/admin/lr3-evidence`, для файлов вычислены контрольные суммы. Это позволило выполнять восстановление на копии, сохранив исходные материалы. Из текста команды установлены параметры шифрования AES-256-CBC и использование SHA-256 при формировании ключа.

Из-за несовместимости параметров первая попытка дешифрования завершилась `bad decrypt`. После сверки параметров использован явный `-md sha256`, и дальнейшая проверка `gzip -t` вернула код 0. Пароль вводился интерактивно.

```
sudo openssl enc -d -aes-256-cbc -md sha256 \
  -in ~/lr3-evidence/important_files.tar.gz.aes \
  -out ~/lr3-evidence/important_files.recovered-v2.tar.gz
sudo gzip -t ~/lr3-evidence/important_files.recovered-v2.tar.gz
echo $?
```

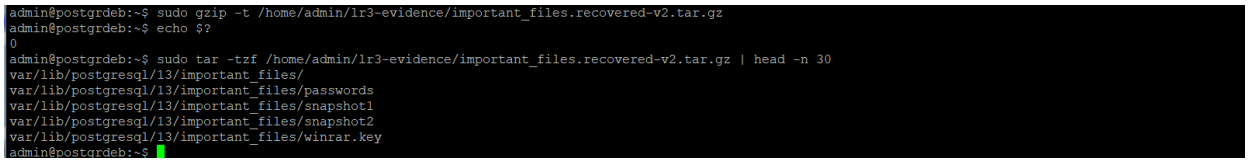


Рисунок 29 — Проверка gzip завершилась кодом 0 и показан состав восстановленного архива

Архив извлечен сначала в отдельный каталог `~/lr3-recovered`. В нем находятся четыре файла: `passwords`, `snapshot1`, `snapshot2` и `winrar.key`.

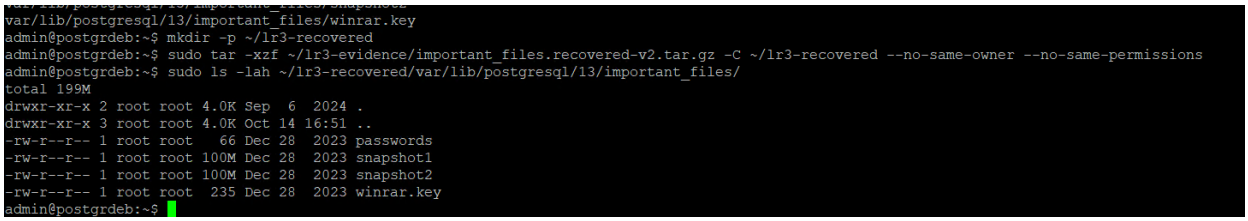


Рисунок 30 — Четыре важных файла после извлечения в отдельный каталог

В конфигурации выявлены два условия избыточного доступа: `listen_addresses` имел значение *, а в `pg_hba.conf` присутствовала строка `host all all all password`. Последняя разрешала парольную аутентификацию для произвольных баз, ролей и адресов, если клиент достигал сервера.

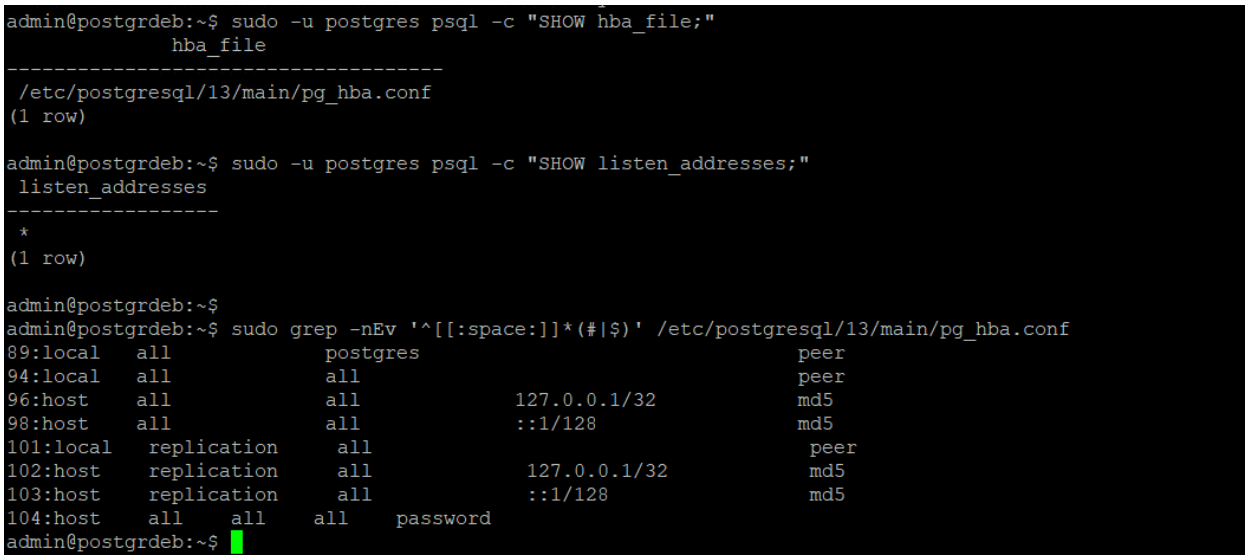


Рисунок 31 — Исходные настройки PostgreSQL с listen_addresses=* и широким правилом HBA

Перед правкой сохранена копия `pg_hba.conf.before`. В `pg_hba.conf` широкая строка закомментирована, локальные правила оставлены. Системное представление `pg_hba_file_rules` не показало ошибок, а `pg_reload_conf` вернул t.

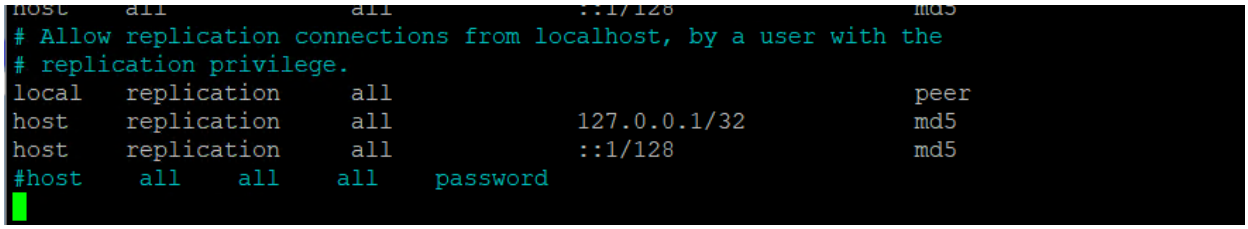


Рисунок 32 — Широкое правило host all all all password закомментировано

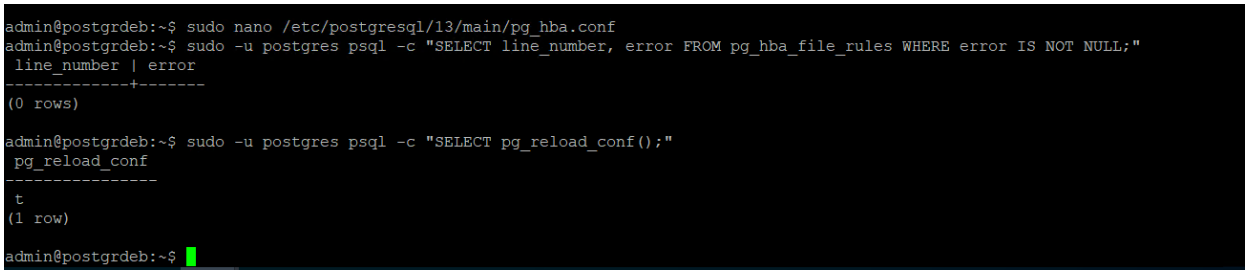


Рисунок 33 — Проверка синтаксиса HBA без ошибок и успешная перезагрузка конфигурации

В `pg_stat_activity` обнаружен удаленный сеанс `postgres@template1` с PID 1729 и `client_addr 10.10.2.254`. Для завершения использован запрос с проверкой PID, роли, базы и адреса. Первый вызов `pg_terminate_backend` вернул t. При повторной проверке подходящих удаленных сеансов не осталось.

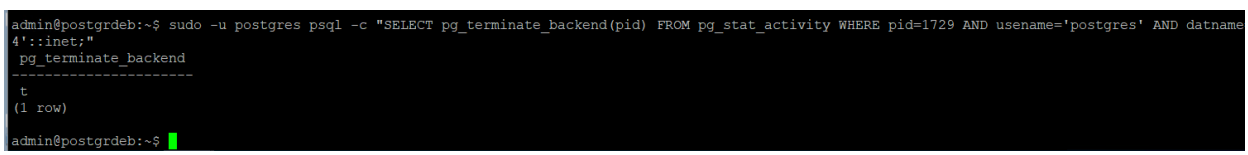


Рисунок 34 — Целевое завершение сеанса PostgreSQL возвращает t

Пароль роли postgres сменен интерактивной метакомандой `\password postgres` в psql. При вводе пароль не отображался. Затем локальный запрос `SELECT current_user, current_database()` вернул postgres и postgres, что подтверждает сохранение локального административного доступа.

```
admin@postgrdeb:~$ sudo -u postgres psql
psql (13.14 (Debian 13.14-0+deb11u1))
Type "help" for help.

postgres=# \password postgres
Enter new password for user "postgres":
Enter it again:
postgres=#
```

Рисунок 35 — Смена пароля роли postgres в psql

Восстановленный каталог `important_files` возвращен в `/var/lib/postgresql/13/`. Повторный список показал все четыре файла. Проверка `diff -r` между извлеченной копией и целевым каталогом завершилась без различий и вернула код 0. Владельцем извлеченных файлов в выполненной процедуре стал root; исходные метаданные владельца отдельно не подтверждались.

```
admin@postgrdeb:~$ sudo cp -a /home/admin/lr3-recovered/var/lib/postgresql/13/important_files /var/lib/postgresql/13/
admin@postgrdeb:~$ sudo ls -lah /var/lib/postgresql/13/important_files/
total 199M
drwxr-xr-x 2 root     root     4.0K Sep  6  2024 .
drwxr-xr-x 4 postgres postgres 4.0K Oct 14 17:07 ..
-rw-r--r-- 1 root     root       66 Dec 28  2023 passwords
-rw-r--r-- 1 root     root     100M Dec 28  2023 snapshot1
-rw-r--r-- 1 root     root     100M Dec 28  2023 snapshot2
-rw-r--r-- 1 root     root      235 Dec 28  2023 winrar.key
admin@postgrdeb:~$ sudo diff -r /home/admin/lr3-recovered/var/lib/postgresql/13/important_files /var/lib/postgresql/13/important_files
admin@postgrdeb:~$ echo $?
0
admin@postgrdeb:~$
```

Рисунок 36 — Важные файлы возвращены в целевой каталог и diff -r завершился кодом 0

Затем в `postgresql.conf` значение `listen_addresses` изменено с `*` на `localhost`, после чего выполнен перезапуск PostgreSQL. SQL-проверка `SHOW listen_addresses` вернула `localhost`. Эта настройка закрывает удаленное TCP-прослушивание, сохраняя работу локальных клиентов.

```
sudo systemctl restart postgresql
sudo -u postgres psql -c "SHOW listen_addresses;"
```

```
admin@postgrdeb:~$ sudo systemctl restart postgresql
admin@postgrdeb:~$ sudo -u postgres psql -c 'SHOW listen_addresses;'
 listen_addresses
------------------
 localhost
(1 row)

admin@postgrdeb:~$
```

Рисунок 37 — После перезапуска PostgreSQL прослушивает localhost

С другой машины стенда, `10.10.4.12`, выполнен `Test-NetConnection 10.10.2.26 -Port 5432`. Узел отвечает на ping, однако `TcpTestSucceeded` имеет значение `False`. Таким

образом, отрицательный результат TCP-проверки согласуется с ограничением PostgreSQL, а не только с полной сетевой недоступностью хоста.

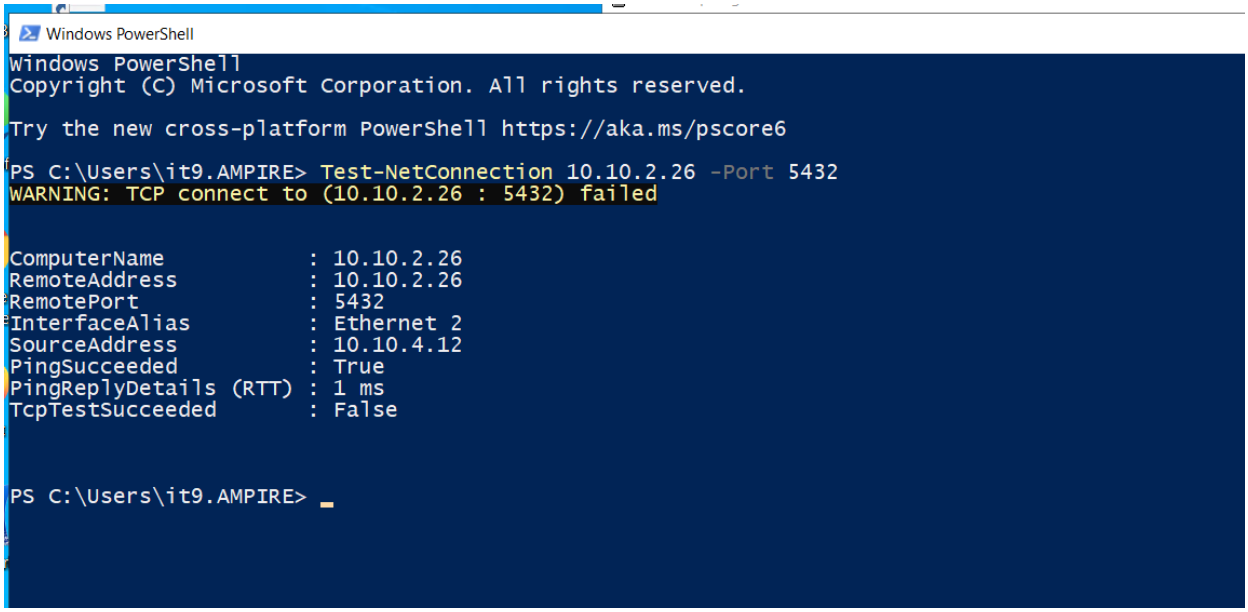


Рисунок 38 — Удаленная TCP-проверка порта 5432 возвращает False при доступном ping

Для PostgreSQL подтверждены восстановление четырех файлов, ограничение HBA, прекращение нежелательного сеанса, смена пароля, переход на `localhost` и закрытие удаленного TCP-доступа. Успех первой обратной оболочки не утверждается: соответствующая запись журнала содержит `Bad file descriptor`.

6 Регистрация инцидентов

В Ampire зарегистрированы три карточки по атакованным активам. Для каждой указаны время, источник, целевой ресурс, описание, рекомендации и индикаторы. Автор карточек в интерфейсе — Гусейнов Тагир; на сохраненных кадрах они имеют первоначальный статус «Новый». Последовательность появления карточек отражена также в приложении А.

Карточка Exchange относится к событию 14.10.2026 около 15:28 и активу `10.10.2.11`. В описание внесены признаки ProxyLogon и Metasploit, в рекомендации — проверка подозрительных файлов и пользователей, ограничение ECP и установка исправления. Упоминание исправления в рекомендации не означает, что его установка была выполнена в этой работе.

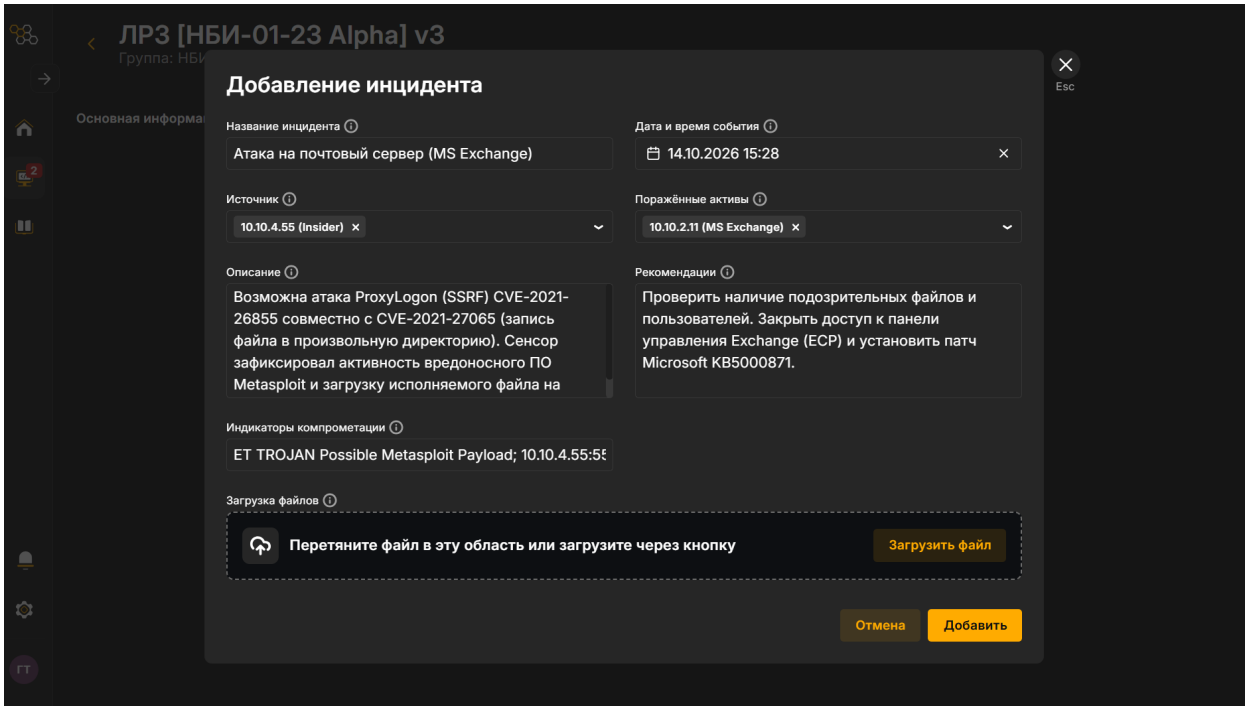


Рисунок 39 — Заполненная форма инцидента атаки на почтовый сервер

Карточка GitLab относится к 15:29 и активу `10.10.2.18`. В ней указаны обработка изображения ExifTool, подозрительная регистрация и признаки внедрения команд. В рекомендациях отражены обновление и ограничение регистрации; фактически в выполненной конфигурации включено подтверждение новых аккаунтов администратором.

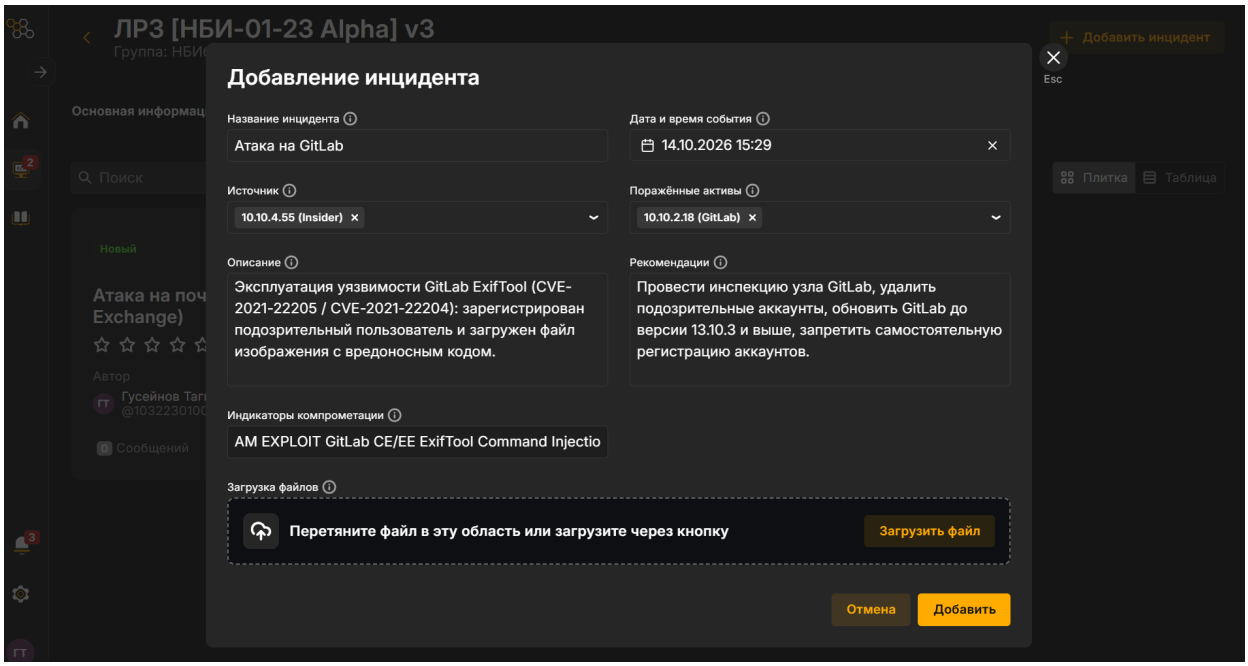


Рисунок 40 — Заполненная форма инцидента атаки на GitLab

Карточка PostgreSQL относится к 15:31 и активу `10.10.2.26`. Она содержит сведения о `COPY FROM PROGRAM`, загрузке ELF и необходимости ограничить доступ. При интерпретации карточки учитывается уточнение по журналу: обратное подключение является попыткой, успех оболочки по этому эпизоду не доказан. Подтвержденным последствием являются зашифрованные файлы и их последующее восстановление.

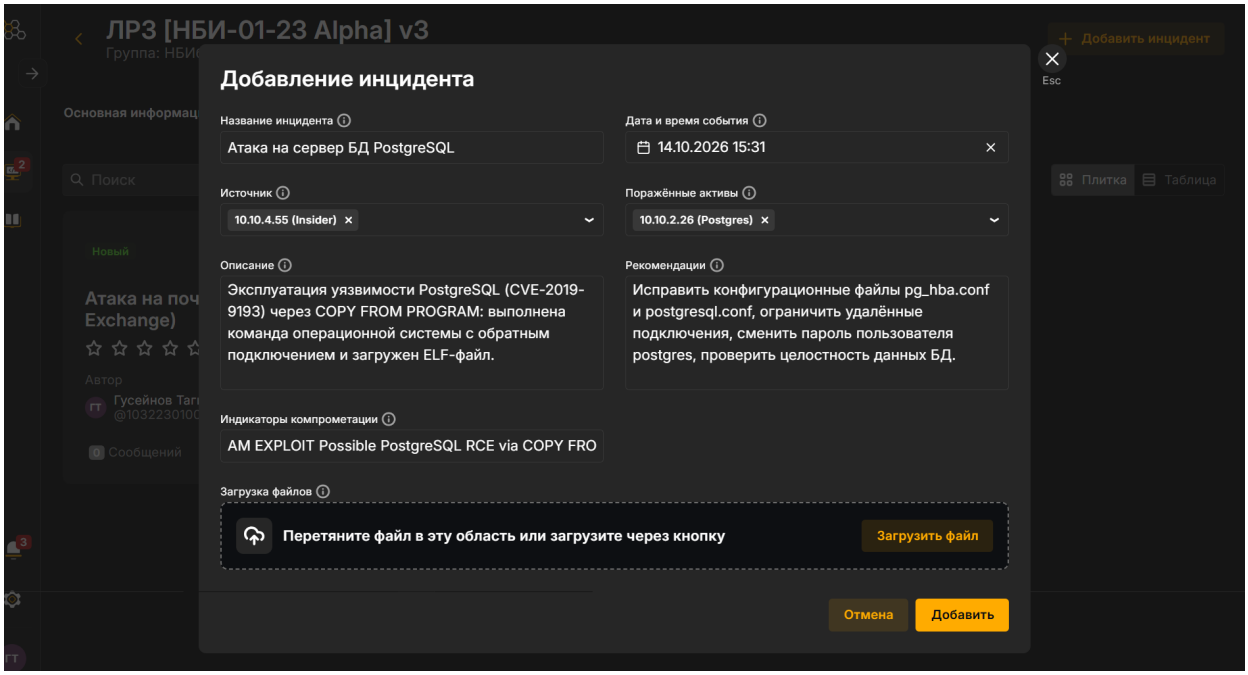


Рисунок 41 — Заполненная форма инцидента атаки на PostgreSQL

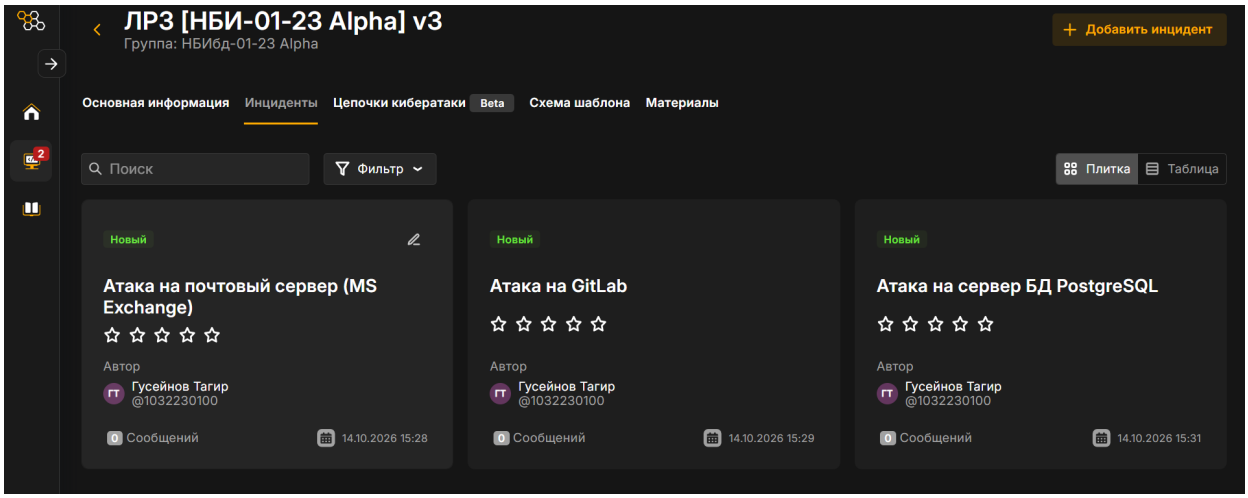


Рисунок 42 — Все три зарегистрированные карточки инцидентов в одной тренировке

Карточки связывают обнаруженные признаки с активами и мерами реагирования.

7 Результаты и обсуждение

7.1 Итоговые результаты по активам

Таблица 3 — Сопоставление последствий и выполненных мер

Актив	Подтвержденное последствие	Выполненные меры	Проверенный результат
Exchange	`hacker` в `Administrators`; два PowerShell-соединения с `10.10.4.55:5556`	ECP `Deny`; удаление `hacker`; завершение атакующего процесса	`hacker` отсутствует; прежние PID и соединения не наблюдаются
GitLab	Пустой репозиторий; процесс `/tmp/idMnwN`	Сохранение доказательств; завершение процесса; restore; обновление CE `13.10.3`; admin approval	`README.md` и `main.py` доступны; 15 служб `run`; аккаунт нарушителя отсутствует
PostgreSQL	Зашифрованный архив; широкое HBA; `listen_addresses=*`	Дешифрование и возврат файлов; HBA; пароль; завершение сеанса; `localhost` и restart	4 файла; diff: 0; SHOW: `localhost`; удаленный 5432 недоступен

На итоговом экране «Основная информация» все шесть элементов имеют статус «Устранено»: Proxylogon, Exchange User, GitLab RCE, GitLab deleter, Postgres misconfig и Postgres encrypt. Поля ответственного отображаются как «Не назначено».

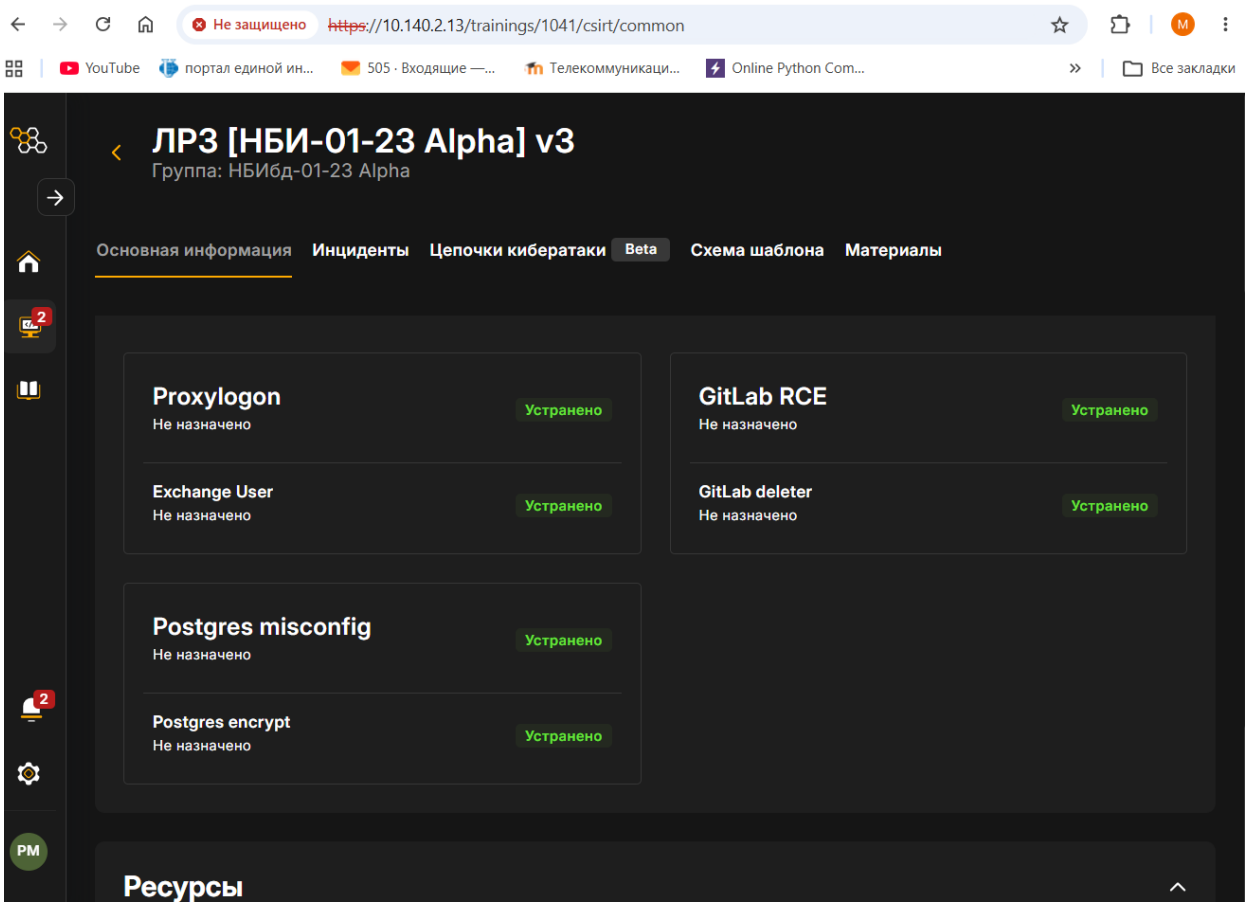


Рисунок 43 — Итог Ampire для тренировки 1041 — три уязвимости и три последствия устранены

7.2 Границы подтвержденного результата

Для восстановленных данных имеются самостоятельные проверки: содержимое проекта GitLab проверено через веб-интерфейс, а файлы PostgreSQL сравнены с извлеченной копией. Для ограничений доступа проверены конфигурация HBA, значение `listen_addresses` и отказ удаленного TCP-подключения к 5432. Для ECP подтверждено сохраненное значение `Deny`. Отдельная внешняя HTTP-проверка не выполнялась.

Названия правил IDS описывают признаки и возможный класс атаки. Они не заменяют доказательство результата на хосте. В частности, `Bad file descriptor` ограничивает вывод об успешности первой обратной оболочки PostgreSQL, а присутствие `10.10.2.254` в трафике не является самостоятельным доказательством конкретной схемы NAT.

Удаление пользователя, прекращение найденных соединений и восстановление сервисов соответствуют учебным задачам. Полное исследование всех механизмов закрепления в ОС и подтверждение установленного исправления Exchange в выполненные проверки не входили.

Последовательность атаки восстановлена в разделе 4.5 по IDS, отдельным пакетам и журналам. Хронология связывает сетевые события с подтвержденными последствиями на трех активах. Отдельная цепочка во вкладке «Цепочки кибератаки» Ampire не создавалась.

8 Заключение

В ходе лабораторной работы мы установили последовательность воздействия на Exchange, GitLab и PostgreSQL, сохранили сетевые и хостовые признаки и зарегистрировали три инцидента. События IDS сопоставлены со временем запуска подозрительного процесса, состоянием учетных записей, содержимым проекта и зашифрованным архивом.

На Exchange ограничен доступ к ECP, удален нелегитимный локальный администратор и устранены наблюдавшиеся атакующие соединения. В GitLab восстановлен репозиторий, выполнено обновление до учебной целевой версии `13.10.3` и включено одобрение регистраций. В PostgreSQL восстановлены четыре файла, изменен пароль и ограничен сетевой доступ; сохранение локальной работы и недоступность удаленного 5432 проверены отдельно.

Итоговый экран тренировки подтверждает статусы «Устранено» для всех трех уязвимостей и трех последствий. Полученный результат показывает значение совместного анализа сетевых событий и состояния хостов: меры реагирования выбирались по конкретным подтвержденным фактам, а успешность восстановления проверялась по данным и работе сервисов.

Приложение А Последовательность регистрации инцидентов

Промежуточные экраны показывают появление карточек в той же тренировке: сначала Exchange, затем GitLab, после чего список дополнен PostgreSQL. Они уточняют последовательность регистрации и дополняют итоговый экран с тремя карточками из раздела 6.

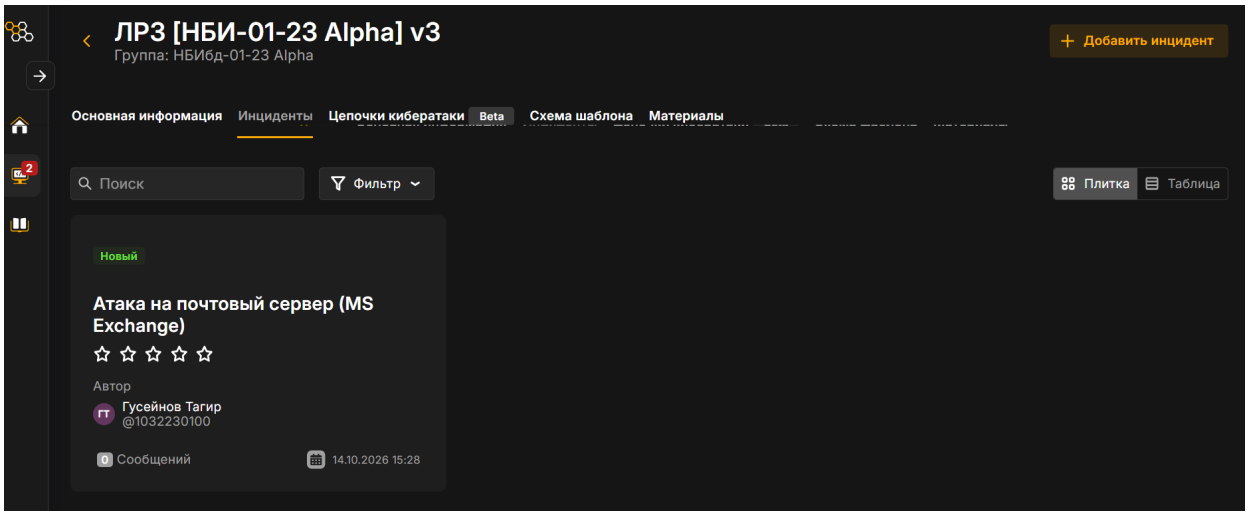


Рисунок 44 — После добавления первой карточки в списке присутствует инцидент Exchange

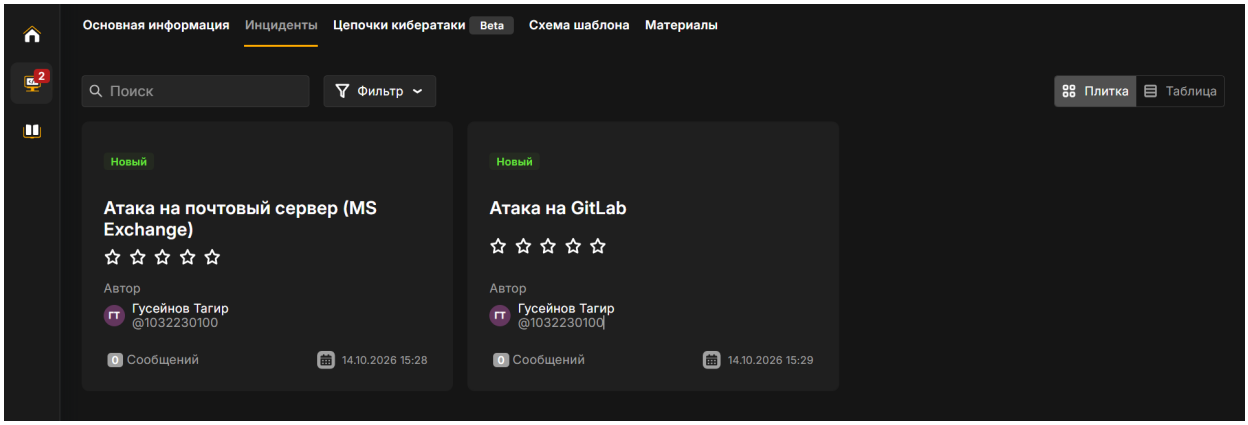


Рисунок 45 — После второго добавления в списке присутствуют инциденты Exchange и GitLab

Приложение Б Реестр ключевых файлов расследования

Для трех локально сохраненных PCAP вычислена SHA-256. Каждый файл содержит отдельный пакет из события сенсора. Контрольная сумма позволяет проверить неизменность конкретной выгрузки; она не заменяет полный дамп сеанса.

Б.1. `IDS_packet_time-2026-10-14T12_31_48.464131Z_ruleid-3202105.pcap`

Размер: 222 байт. Алгоритм: SHA-256.

`462f161f2590b8a8a770e74abfc069e1bc0a56ae905bacf5cd5456ed43666ee7`

Б.2. `IDS_packet_time-2026-10-14T12_32_05.359224Z_ruleid-3121915 (1).pcap`

Размер: 1554 байт. Алгоритм: SHA-256.

`64a3398e2d61c5bc13dc8eede58d0bf3c7a8ca6e424eec5dff7bf0c17ec60a07`

Б.3. `IDS_packet_time-2026-10-14T12_29_14.264548Z_ruleid-3191163.pcap`

Размер: 1709 байт. Алгоритм: SHA-256.

`3aba34a7c1daac5fc58038d9bc47812b0bc987bffd4ef7c934fc78b25bd17987`

Сохраненный исполняемый файл `/tmp/idMnwN` с GitLab помещен на хосте в lr3-gitlab-evidence/idMnwN.bin. Его SHA-256 зафиксирована при сохранении:

`6b84db4d3020ee335aeb837d39316bdd54acc9f24d668f3a59fe84627460e57f`

Исходные журналы, зашифрованный архив и резервные копии сохранялись до изменений.